

NIST SP 800-53 Rev 5 control SA-8.11 (Inverse Modification Threshold) summarizes the requirements for this control: SA-8.11 · Inverse Modification Threshold Control Statement: Implement the security design principle of inverse modification threshold in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of inverse modification threshold in [organization-defined parameter]. The principle of inverse modification threshold builds on the principle of trusted components and the principle of hierarchical trust and states that the degree of protection provided to a comp

NIST SP 800-53 Rev 5 control SA-15.11 (Archive System or Component) summarizes the requirements for this control: SA-15.11 · Archive System or Component Control Statement: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review. Supplemental Guidance: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review

NIST SP 800-53 Rev 5 control SA-11 (Developer Testing and Evaluation) is assessed by examining, interviewing, and testing: SA-11 · Developer Testing and Evaluation Control Statement: Require the developer of the system, system component, or system service, at all post-design stages of the system development life cycle, to: a. Develop and implement a plan for ongoing security and privacy control assessments; b. Perform [organization-defined parameter] testing/evaluation [organization-defined parameter] at [organization-defined parameter]; c. Produce evidence of the execution of the assessment plan and the results of

NIST SP 800-171 Rev 3 control 03.16.03 (03.16.03 External System Services) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Services Acquisition (SA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

The organization has established and implemented the processes to identify, assess, and manage supply chain risks. | ID.SC-1: Cyber supply chain risk management processes are identified, established, assessed, managed, and agreed to by organizational stakeholders | · CIS CSC 4 · COBIT 5 APO10.01, APO10.04, APO12.04, APO12.05, APO13.02, BAI01.03, BAI02.03, BAI04.02 · ISA 62443-2-1:2009 4.3.4.2 · ISO/IEC 27001:2013 A.15.1.1, A.15.1.2, A.15.1.3, A.15.2.1, A.15.2.2 · NIST SP 800-53 Rev. 4 SA-9, SA-12, PM-9 | | IDENTIFY (ID) | Supply Chain Risk Management (ID.SC): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support risk decisions associated with managing supply chain risk. The organization has established and implemented the processes to identify, assess, and manage supply chain risks. | ID.SC-2: Suppliers and third-party partners of information systems, components, and services are identified, prioritized, and assessed using a cyber supply chain risk assessment process | · COBIT 5 APO10.01, APO10.02, APO10.04, APO10.05, APO12.01, APO12.02, APO12.03, APO12.04, APO12.05, APO12.06, APO13.02, BAI02.03 · ISA 62443-2-1:2009 4.2.3.1, 4.2.3.2, 4.2.3.3, 4.2.3.4, 4.2.3.6, 4.2.3.8, 4.2.3.9, 4.2.3.10, 4.2.3.12, 4.2.3.13, 4.2.3.14 · ISO/IEC 27001:2013 A.15.2.1, A.15.2.2 · NIST SP 800-53 Rev. 4 RA-2, RA-3, SA-12, SA-14, SA-15, PM-9 |

NIST SP 800-53 Rev 5 control SA-4.11 (System of Records) summarizes the requirements for this control: SA-4.11 · System of Records Control Statement: Include [organization-defined parameter] in the acquisition contract for the operation of a system of records on behalf of an organization to accomplish an organizational mission or function. Supplemental Guidance: Include [organization-defined parameter] in the acquisition contract for the operation of a system of records on behalf of an organization to accomplish an organizational mission or function. When, by contract, an organization provides

NIST SP 800-171 Rev 3 control 03.16.03 (03.16.03 External System Services) requires organizations to implement the following: Control Statement: SR-03.16.03.a Require the providers of external system services used for the processing, storage, or transmission of CUI to comply with the following security requirements: [organization-defined parameter]. SR-03.16.03.b Define and document user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers. SR-03.16.03.c Implement processes, methods, and

techniques to monitor security requirement compliance by external service providers on an ongoing basis. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.16.03.

NIST SP 800-53 Rev 5 control SA-11.1 (Static Code Analysis) is assessed by examining, interviewing, and testing: SA-11.1 · Static Code Analysis Control Statement: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Supplemental Guidance: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Static code analysis provides a technology and methodology for security

NIST SP 800-53 Rev 5 control SA-10.1 (Software and Firmware Integrity Verification) is assessed by examining, interviewing, and testing: SA-10.1 · Software and Firmware Integrity Verification Control Statement: Require the developer of the system, system component, or system service to enable integrity verification of software and firmware components. Supplemental Guidance: Require the developer of the system, system component, or system service to enable integrity verification of software and firmware components. Software and firmware integrity verification allows organizations to detect unauthorized changes to software and fi

NIST SP 800-53 Rev 5 control SA-10.4 (Trusted Generation) is assessed by examining, interviewing, and testing: SA-10.4 · Trusted Generation Control Statement: Require the developer of the system, system component, or system service to employ tools for comparing newly generated versions of security-relevant hardware descriptions, source code, and object code with previous versions. Supplemental Guidance: Require the developer of the system, system component, or system service to employ tools for comparing newly generated versions of security-relevant hardware descriptions, source code, and object code w

SA-15.10 · Incident Response Plan Control Statement: Require the developer of the system, system component, or system service to provide, implement, and test an incident response plan. Supplemental Guidance: Require the developer of the system, system component, or system service to provide, implement, and test an incident response plan. The incident response plan provided by developers may provide information not readily available to organizations and be incorporated into organizational incident response plans. Developer information may also be extremely helpful, such as when organizations respond to vulnerabilities in commercial off-the-shelf products.

NIST SP 800-53 Rev 5 control SA-3.2 (Use of Live or Operational Data) is defined as follows: SA-3.2 · Use of Live or Operational Data Control Statement: (a) Approve, document, and control the use of live data in preproduction environments for the system, system component, or system service; and (b) Protect preproduction environments for the system, system component, or system service at the same impact or classification level as any live data in use within the preproduction environments. Supplemental Guidance: (a) Approve, document, and control the use of live data in preproduction environments for the system, system component, or system service; and (b) Protect preproduction enviro

NIST SP 800-53 Rev 5 control SA-10.1 (Software and Firmware Integrity Verification) is defined as follows: SA-10.1 · Software and Firmware Integrity Verification Control Statement: Require the developer of the system, system component, or system service to enable integrity verification of software and firmware components. Supplemental Guidance: Require the developer of the system, system component, or system service to enable integrity verification of software and firmware components. Software and firmware integrity verification allows organizations to detect unauthorized changes to software and firmware components using developer-provided tools, techniques, and mechanisms. The integrity checking

NIST SP 800-53 Rev 5 control SA-15.5 (Attack Surface Reduction) summarizes the requirements for this control: SA-15.5 · Attack Surface Reduction Control Statement: Require the developer of the system, system component, or system service to reduce attack surfaces to [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to reduce attack surfaces to [organization-defined parameter]. Attack surface reduction is

closely aligned with threat and vulnerability analyses and system architecture and design. Attack surface reduction is a

NIST SP 800-53 Rev 5 control SA-10.7 (Security and Privacy Representatives) is assessed by examining, interviewing, and testing: SA-10.7 · Security and Privacy Representatives Control Statement: Require [organization-defined parameter] to be included in the [organization-defined parameter]. Supplemental Guidance: Require [organization-defined parameter] to be included in the [organization-defined parameter]. Information security and privacy representatives can include system security officers, senior agency information security officers, senior agency officials for privacy, and system privacy officers. Representation by

NIST SP 800-53 Rev 5 control SA-15.11 (Archive System or Component) is defined as follows: SA-15.11 · Archive System or Component Control Statement: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review. Supplemental Guidance: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review. Archiving system or system components requires the developer to retain key development artifacts,

SA-8.11 · Inverse Modification Threshold Control Statement: Implement the security design principle of inverse modification threshold in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of inverse modification threshold in [organization-defined parameter]. The principle of inverse modification threshold builds on the principle of trusted components and the principle of hierarchical trust and states that the degree of protection provided to a component is commensurate with its trustworthiness. As the trust placed in a component increases, the protection against unauthorized modification of the component also increases to the same degree. Protection from unauthorized modification can come in the form of the component's own self-protection and innate trustworthiness, or it can come from the protections afforded to the component from other elements or attributes of the security architecture (to include protections in the environment of operation).

NIST SP 800-53 Rev 5 control SA-8.1 (Clear Abstractions) is defined as follows: SA-8.1 · Clear Abstractions Control Statement: Implement the security design principle of clear abstractions. Supplemental Guidance: Implement the security design principle of clear abstractions. The principle of clear abstractions states that a system has simple, well-defined interfaces and functions that provide a consistent and intuitive view of the data and how the data is managed. The clarity, simplicity, necessity, and sufficiency of the system interfaces combined with a precise definition of their functional behavior promotes ease of analysis, inspection, and testing as well as the c

SA-8.12 · Hierarchical Protection Control Statement: Implement the security design principle of hierarchical protection in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of hierarchical protection in [organization-defined parameter]. The principle of hierarchical protection states that a component need not be protected from more trustworthy components. In the degenerate case of the most trusted component, it protects itself from all other components. For example, if an operating system kernel is deemed the most trustworthy component in a system, then it protects itself from all untrusted applications it supports, but the applications, conversely, do not need to protect themselves from the kernel. The trustworthiness of users is a consideration for applying the principle of hierarchical protection. A trusted system need not protect itself from an equally trustworthy user, reflecting use of untrusted systems in "system high" environments where users are highly trustworthy and where other protections are put in place to bound and protect the "system high" execution environment.

SA-15.5 · Attack Surface Reduction Control Statement: Require the developer of the system, system component, or system service to reduce attack surfaces to [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to reduce attack surfaces to [organization-defined parameter]. Attack surface reduction is closely aligned with threat and vulnerability analyses and system architecture and design. Attack surface reduction is a means of reducing risk to organizations by giving attackers less opportunity to exploit weaknesses or deficiencies (i.e., potential vulnerabilities) within systems, system

components, and system services. Attack surface reduction includes implementing the concept of layered defenses, applying the principles of least privilege and least functionality, applying secure software development practices, deprecating unsafe functions, reducing entry points available to unauthorized users, reducing the amount of code that executes, and eliminating application programming interfaces (APIs) that are vulnerable to attacks.

NIST SP 800-171 Rev 3 control 03.16.01 (03.16.01 Security Engineering Principles) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Services Acquisition (SA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

SA-8.9 · Trusted Components Control Statement: Implement the security design principle of trusted components in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of trusted components in [organization-defined parameter]. The principle of trusted components states that a component is trustworthy to at least a level commensurate with the security dependencies it supports (i.e., how much it is trusted to perform its security functions by other components). This principle enables the composition of components such that trustworthiness is not inadvertently diminished and the trust is not consequently misplaced. Ultimately, this principle demands some metric by which the trust in a component and the trustworthiness of a component can be measured on the same abstract scale. The principle of trusted components is particularly relevant when considering systems and components in which there are complex chains of trust dependencies. A trust dependency is also referred to as a trust relationship and there may be chains of trust relationships. The principle of trusted components also applies to a compound component that consists of subcomponents (e.g., a subsystem), which may have varying levels of trustworthiness. The conservative assumption is that the trustworthiness of a compound component is that of its least trustworthy subcomponent. It may be possible to provide a security engineering rationale that the trustworthiness of a particular compound component is greater than the conservative assumption. However, any such rationale reflects logical reasoning based on a clear statement of the trustworthiness objectives as well as relevant and credible evidence. The trustworthiness of a compound component is not the same as increased application of defense-in-depth layering within the component or a replication of components. Defense-in-depth techniques do not increase the trustworthiness of the whole above that of the least trustworthy component.

NIST SP 800-53 Rev 5 control SA-11.1 (Static Code Analysis) is defined as follows: SA-11.1 · Static Code Analysis Control Statement: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Supplemental Guidance: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Static code analysis provides a technology and methodology for security reviews and includes checking for weaknesses in the code as well as for the incorporation of library

NIST SP 800-53 Rev 5 control SA-11.4 (Manual Code Reviews) is assessed by examining, interviewing, and testing: SA-11.4 · Manual Code Reviews Control Statement: Require the developer of the system, system component, or system service to perform a manual code review of [organization-defined parameter] using the following processes, procedures, and/or techniques: [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to perform a manual code review of [organization-defined parameter] using the following processes, procedures, and/o

Under the FedRAMP High baseline, SA-4.9 (SA-4.9 Functions, Ports, Protocols, and Services in Use): FedRAMP High Baseline · SA-4.9 · Functions, Ports, Protocols, and Services in Use Control Statement: Require the developer of the system, system component, or system service to identify the functions, ports, protocols, and services intended for organizational use. Supplemental Guidance: Require the developer of the system, system component, or system service to identify the functions, ports, protocols, and services intended for organizational use. The identification of functions, ports, protoc

NIST SP 800-53 Rev 5 control SA-20 (Customized Development of Critical Components) summarizes the requirements for this control: SA-20 · Customized Development of Critical Components Control

Statement: Reimplement or custom develop the following critical system components: [organization-defined parameter]. Supplemental Guidance: Reimplement or custom develop the following critical system components: [organization-defined parameter]. Organizations determine that certain system components likely cannot be trusted due to specific threats to and vulnerabilities in those components for which there are no viable security controls

NIST SP 800-53 Rev 5 control SA-9.8 (Processing and Storage Location · U.S. Jurisdiction) summarizes the requirements for this control: SA-9.8 · Processing and Storage Location · U.S. Jurisdiction Control Statement: Restrict the geographic location of information processing and data storage to facilities located within in the legal jurisdictional boundary of the United States. Supplemental Guidance: Restrict the geographic location of information processing and data storage to facilities located within in the legal jurisdictional boundary of the United States. The geographic location of information processing and data storage

NIST SP 800-53 Rev 5 control SA-8.29 (Repeatable and Documented Procedures) is defined as follows: SA-8.29 · Repeatable and Documented Procedures Control Statement: Implement the security design principle of repeatable and documented procedures in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of repeatable and documented procedures in [organization-defined parameter]. The principle of repeatable and documented procedures states that the techniques and methods employed to construct a system component permit the same component to be completely and correctly reconstructed at a later time. Repeatable and documented procedures support the development

SA-11.6 · Attack Surface Reviews Control Statement: Require the developer of the system, system component, or system service to perform attack surface reviews. Supplemental Guidance: Require the developer of the system, system component, or system service to perform attack surface reviews. Attack surfaces of systems and system components are exposed areas that make those systems more vulnerable to attacks. Attack surfaces include any accessible areas where weaknesses or deficiencies in the hardware, software, and firmware components provide opportunities for adversaries to exploit vulnerabilities. Attack surface reviews ensure that developers analyze the design and implementation changes to systems and mitigate attack vectors generated as a result of the changes. The correction of identified flaws includes deprecation of unsafe functions.

NIST SP 800-53 Rev 5 control SA-3.3 (Technology Refresh): SA-3.3 · Technology Refresh Control Statement: Plan for and implement a technology refresh schedule for the system throughout the system development life cycle. Supplemental Guidance: Plan for and implement a technology refresh schedule for the system throughout the system development life cycle. Technology refresh planning may encompass hardware, software, firmware, processes, personnel skills

Under the FedRAMP High baseline, SA-15 (SA-15 Development Process, Standards, and Tools): FedRAMP High Baseline · SA-15 · Development Process, Standards, and Tools Control Statement: a. Require the developer of the system, system component, or system service to follow a documented development process that: 1. Explicitly addresses security and privacy requirements; 2. Identifies the standards and tools used in the development process; 3. Documents the specific tool options and tool configurations used in the development process; and 4. Documents, manages, and ensures the integrity

NIST SP 800-53 Rev 5 control SA-8.27 (Human Factored Security) is assessed by examining, interviewing, and testing: SA-8.27 · Human Factored Security Control Statement: Implement the security design principle of human factored security in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of human factored security in [organization-defined parameter]. The principle of human factored security states that the user interface for security functions and supporting services is intuitive, user-friendly, and provides feedback for user actions that affect such policy and

Under the FedRAMP Moderate baseline, SA-11.1 (SA-11.1 Static Code Analysis): FedRAMP Moderate Baseline · SA-11.1 · Static Code Analysis Control Statement: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Supplemental Guidance: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common

flaws and document the results of the analysis. Static code analysis provides a technology

NIST SP 800-171 Rev 3 control 03.16.01 (03.16.01 Security Engineering Principles) requires organizations to implement the following: 03.16.01 · Security Engineering Principles Supplemental Guidance: Organizations apply systems security engineering principles to new development systems. For legacy systems, organizations apply systems security engineering principles to system modifications to the extent feasible, given the current state of hardware, software, and firmware components. The application of systems security engineering principles helps to develop trustworthy, secure, and resilient systems and reduce the susceptibility. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.16.01.

NIST SP 800-53 Rev 5 control SA-10.3 (Hardware Integrity Verification) is assessed by examining, interviewing, and testing: SA-10.3 · Hardware Integrity Verification Control Statement: Require the developer of the system, system component, or system service to enable integrity verification of hardware components. Supplemental Guidance: Require the developer of the system, system component, or system service to enable integrity verification of hardware components. Hardware integrity verification allows organizations to detect unauthorized changes to hardware components using developer-provided tools, techniques, met

NIST SP 800-171 Rev 3 control 03.16.02 (03.16.02 Unsupported System Components) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Services Acquisition (SA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SA-15.2 (Security and Privacy Tracking Tools) is assessed by examining, interviewing, and testing: SA-15.2 · Security and Privacy Tracking Tools Control Statement: Require the developer of the system, system component, or system service to select and employ security and privacy tracking tools for use during the development process. Supplemental Guidance: Require the developer of the system, system component, or system service to select and employ security and privacy tracking tools for use during the development process. System development teams select and deploy security and privacy tracki

Under the FedRAMP High baseline, SA-16 (SA-16 Developer-provided Training): FedRAMP High Baseline · SA-16 · Developer-provided Training Control Statement: Require the developer of the system, system component, or system service to provide the following training on the correct use and operation of the implemented security and privacy functions, controls, and/or mechanisms: [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to provide the following training on the correct use and operation of

NIST SP 800-53 Rev 5 control SA-17.5 (Conceptually Simple Design) is defined as follows: SA-17.5 · Conceptually Simple Design Control Statement: Require the developer of the system, system component, or system service to: (a) Design and structure the security-relevant hardware, software, and firmware to use a complete, conceptually simple protection mechanism with precisely defined semantics; and (b) Internally structure the security-relevant hardware, software, and firmware with specific regard for this mechanism. Supplemental Guidance: Require the developer of the system, system component, or system service to: (a) Design and structure the security-relevant hardware, software,

NIST SP 800-53 Rev 5 control SA-8.9 (Trusted Components) summarizes the requirements for this control: SA-8.9 · Trusted Components Control Statement: Implement the security design principle of trusted components in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of trusted components in [organization-defined parameter]. The principle of trusted components states that a component is trustworthy to at least a level commensurate with the security dependencies it supports (i.e., how much it is trusted to perform its security functions by other compon

NIST SP 800-53 Rev 5 control SA-8.16 (Self-reliant Trustworthiness) summarizes the requirements for this control: SA-8.16 · Self-reliant Trustworthiness Control Statement: Implement the security

design principle of self-reliant trustworthiness in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of self-reliant trustworthiness in [organization-defined parameter]. The principle of self-reliant trustworthiness states that systems minimize their reliance on other systems for their own trustworthiness. A system is trustworthy by default, and any connection to an

Under the FedRAMP High baseline, SA-22 (SA-22 Unsupported System Components): FedRAMP High Baseline · SA-22 · Unsupported System Components Control Statement: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the following options for alternative sources for continued support for unsupported components [organization-defined parameter]. Supplemental Guidance: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufac

FedRAMP High Baseline · SA-15 · Development Process, Standards, and Tools Control Statement: a. Require the developer of the system, system component, or system service to follow a documented development process that: 1. Explicitly addresses security and privacy requirements; 2. Identifies the standards and tools used in the development process; 3. Documents the specific tool options and tool configurations used in the development process; and 4. Documents, manages, and ensures the integrity of changes to the process and/or tools used in development; and b. Review the development process, standards, tools, tool options, and tool configurations [organization-defined parameter] to determine if the process, standards, tools, tool options and tool configurations selected and employed can satisfy the following security and privacy requirements: [organization-defined parameter]. Supplemental Guidance: a. Require the developer of the system, system component, or system service to follow a documented development process that: 1. Explicitly addresses security and privacy requirements; 2. Identifies the standards and tools used in the development process; 3. Documents the specific tool options and tool configurations used in the development process; and 4. Documents, manages, and ensures the integrity of changes to the process and/or tools used in development; and b. Review the development process, standards, tools, tool options, and tool configurations [organization-defined parameter] to determine if the process, standards, tools, tool options and tool configurations selected and employed can satisfy the following security and privacy requirements: [organization-defined parameter]. Development tools include programming languages and computer-aided design systems. Reviews of development processes include the use of maturity models to determine the potential effectiveness of such processes. Maintaining the integrity of changes to tools and processes facilitates effective supply chain risk assessment and mitigation. Such integrity requires configuration control throughout the system development life cycle to track authorized changes and prevent unauthorized changes. Assessment Objectives: a. Require the developer of the system, system component, or system service to follow a documented development process that: 1. Explicitly addresses security and privacy requirements; 2. Identifies the standards and tools used in the development process; 3. Documents the specific tool options and tool configurations used in the development process; and 4. Documents, manages, and ensures the integrity of changes to the process and/or tools used in development; and b. Review the development process, standards, tools, tool options, and tool configurations [organization-defined parameter] to determine if the process, standards, tools, tool options and tool configurations selected and employed can satisfy the following security and privacy requirements: [organization-defined parameter]. FedRAMP Parameter Values: sa-15_prm_2: organization-defined security and privacy requirements sa-15_odp.01: frequency as before first use and annually thereafter sa-15_odp.02: FedRAMP Security Authorization requirements sa-15_odp.03: privacy requirements to be satisfied by the process, standards, tools, tool options, and tool configurations are defined;

NIST SP 800-171 Rev 3 control 03.16.02 (03.16.02 Unsupported System Components) falls under the System and Services Acquisition family. Control Statement: SR-03.16.02.a Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer. SR-03.16.02.b Provide options for risk mitigation or alternative sources for continued support for unsupported components that cannot be replaced. Supplemental Guidance: Support for system components includes software patches, firmware updates, replacement parts, and maintenance contracts. An example of unsupported components includes when vendors no longer provide critical software patches or product updates, which can result in opportunities for adversaries to exploit weaknesses or deficiencies in the installed components. Exceptions to replacing unsupported system components include systems that provide critical mission or business capa

Under the FedRAMP High baseline, SA-5 (SA-5 System Documentation): FedRAMP High Baseline · SA-5 · System Documentation Control Statement: a. Obtain or develop administrator documentation for the system, system component, or system service that describes: 1. Secure configuration, installation, and operation of the system, component, or service; 2. Effective use and maintenance of security and privacy functions and mechanisms; and 3. Known vulnerabilities regarding configuration and use of administrative or privileged functions; b. Obtain or develop user d

Under the FedRAMP Moderate baseline, SA-15 (SA-15 Development Process, Standards, and Tools): FedRAMP Moderate Baseline · SA-15 · Development Process, Standards, and Tools Control Statement: a. Require the developer of the system, system component, or system service to follow a documented development process that: 1. Explicitly addresses security and privacy requirements; 2. Identifies the standards and tools used in the development process; 3. Documents the specific tool options and tool configurations used in the development process; and 4. Documents, manages, and ensures the

NIST SP 800-53 Rev 5 control SA-4.2 (Design and Implementation Information for Controls) summarizes the requirements for this control: SA-4.2 · Design and Implementation Information for Controls Control Statement: Require the developer of the system, system component, or system service to provide design and implementation information for the controls that includes: [organization-defined parameter] at [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to provide design and implementation information for the controls that includes: [organization-defi

NIST SP 800-53 Rev 5 control SA-23 (Specialization) summarizes the requirements for this control: SA-23 · Specialization Control Statement: Employ [organization-defined parameter] on [organization-defined parameter] supporting mission essential services or functions to increase the trustworthiness in those systems or components. Supplemental Guidance: Employ [organization-defined parameter] on [organization-defined parameter] supporting mission essential services or functions to increase the trustworthiness in those systems or components. It is often necessary for a system or system compon

NIST SP 800-53 Rev 5 control SA-9.4 (Consistent Interests of Consumers and Providers) summarizes the requirements for this control: SA-9.4 · Consistent Interests of Consumers and Providers Control Statement: Take the following actions to verify that the interests of [organization-defined parameter] are consistent with and reflect organizational interests: [organization-defined parameter]. Supplemental Guidance: Take the following actions to verify that the interests of [organization-defined parameter] are consistent with and reflect organizational interests: [organization-defined parameter]. As organizations increasingly u

NIST SP 800-171 Rev 3 control 03.16.03 (03.16.03 External System Services) is assessed by examining the following: Assessment Objectives: - the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: [organization-defined parameter]. - processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented. - user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers, are defined and documented.

Under the FedRAMP High baseline, SA-9.2 (SA-9.2 Identification of Functions, Ports, Protocols, and Services): FedRAMP High Baseline · SA-9.2 · Identification of Functions, Ports, Protocols, and Services Control Statement: Require providers of the following external system services to identify the functions, ports, protocols, and other services required for the use of such services: [organization-defined parameter]. Supplemental Guidance: Require providers of the following external system services to identify the functions, ports, protocols, and other services required for the use of such services: [or

NIST SP 800-171 Rev 3 control 03.16.01 (03.16.01 Security Engineering Principles) requires organizations to implement the following: 03.16.01 · Security Engineering Principles Supplemental Guidance: Organizations apply systems security engineering principles to new development systems. For legacy systems, organizations apply systems security engineering principles to system modifications to the extent feasible, given the current state of hardware, software, and firmware components. The application of systems security engineering principles helps to develop trustworthy,

secure, and resilient systems and reduce the susceptibility of organizations to disruptions, hazards. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.16.01.

NIST SP 800-171 Rev 3 control 03.16.01 (03.16.01 Security Engineering Principles) falls under the System and Services Acquisition family. 03.16.01 · Security Engineering Principles Supplemental Guidance: Organizations apply systems security engineering principles to new development systems. For legacy systems, organizations apply systems security engineering principles to system modifications to the extent feasible, given the current state of hardware, software, and firmware components. The application of systems security engineering principles helps to develop trustworthy, secure, and resilient systems and reduce the susceptibility of organizations to disruptions, hazards. Supplemental Guidance: Organizations apply systems security engineering principles to new development systems. For legacy systems, organizations apply systems security engineering principles to system modifications to the extent feasible, given the current state of hardware, software, and firmware components. The application of systems security engineering principles helps to develop trustworthy, secure, and resilient systems and reduce the susceptibility of organizations to disruptions, hazards.

NIST SP 800-53 Rev 5 control SA-15.5 (Attack Surface Reduction) is assessed by examining, interviewing, and testing: SA-15.5 · Attack Surface Reduction Control Statement: Require the developer of the system, system component, or system service to reduce attack surfaces to [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to reduce attack surfaces to [organization-defined parameter]. Attack surface reduction is closely aligned with threat and vulnerability analyses and system architecture and design. Attack surface reduction is a

and d. Distribute documentation to [Assignment: organization-defined personnel or roles]. Discussion: System documentation helps personnel understand the implementation and operation of controls. Organizations consider establishing specific measures to determine the quality and completeness of the content provided. System documentation may be used to support the management of supply chain risk, incident response, and other functions. Personnel or roles that require documentation include system owners, system security officers, and system administrators. Attempts to obtain documentation include contacting manufacturers or suppliers and conducting web-based searches. The inability to obtain documentation may occur due to the age of the system or component or the lack of support from developers and contractors.

NIST SP 800-53 Rev 5 control SA-8.5 (Efficiently Mediated Access): SA-8.5 · Efficiently Mediated Access Control Statement: Implement the security design principle of efficiently mediated access in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of efficiently mediated access in [organization-defined parameter]. The principle of efficiently mediated access states that policy enforcement mechanisms utilize the least

NIST SP 800-53 Rev 5 control SA-8.7 (Reduced Complexity) is assessed by examining, interviewing, and testing: SA-8.7 · Reduced Complexity Control Statement: Implement the security design principle of reduced complexity in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of reduced complexity in [organization-defined parameter]. The principle of reduced complexity states that the system design is as simple and small as possible. A small and simple design is more understandable, more analyzable, and less prone to error. The reduced complexity principle applies

NIST SP 800-53 Rev 5 control SA-9.6 (Organization-controlled Cryptographic Keys) summarizes the requirements for this control: SA-9.6 · Organization-controlled Cryptographic Keys Control Statement: Maintain exclusive control of cryptographic keys for encrypted material stored or transmitted through an external system. Supplemental Guidance: Maintain exclusive control of cryptographic keys for encrypted material stored or transmitted through an external system. Maintaining exclusive control of cryptographic keys in an external system prevents decryption of organizational data by external system staff. Organizational co

Under the FedRAMP High baseline, SA-11.1 (SA-11.1 Static Code Analysis): FedRAMP High Baseline · SA-11.1 · Static Code Analysis Control Statement: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and

document the results of the analysis. Supplemental Guidance: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Static code analysis provides a technology and

SA-10.2 · Alternative Configuration Management Processes Control Statement: Provide an alternate configuration management process using organizational personnel in the absence of a dedicated developer configuration management team. Supplemental Guidance: Provide an alternate configuration management process using organizational personnel in the absence of a dedicated developer configuration management team. Alternate configuration management processes may be required when organizations use commercial off-the-shelf information technology products. Alternate configuration management processes include organizational personnel who review and approve proposed changes to systems, system components, and system services and conduct security and privacy impact analyses prior to the implementation of changes to systems, components, or services.

NIST SP 800-53 Rev 5 control SA-8 (Security and Privacy Engineering Principles) is assessed by examining, interviewing, and testing: SA-8 · Security and Privacy Engineering Principles Control Statement: Apply the following systems security and privacy engineering principles in the specification, design, development, implementation, and modification of the system and system components: [organization-defined parameter]. Supplemental Guidance: Apply the following systems security and privacy engineering principles in the specification, design, development, implementation, and modification of the system and system components: [

Under the FedRAMP Low baseline, SA-4.10 (SA-4.10 Use of Approved PIV Products): FedRAMP Low Baseline · SA-4.10 · Use of Approved PIV Products Control Statement: Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational systems. Supplemental Guidance: Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational systems. Products on the FIPS 201-approved prod

Implementing 03.16.02 (03.16.02 Unsupported System Components) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.16.02 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.16.02 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Under the FedRAMP High baseline, SA-4.5 (SA-4.5 System, Component, and Service Configurations): FedRAMP High Baseline · SA-4.5 · System, Component, and Service Configurations Control Statement: Require the developer of the system, system component, or system service to: (a) Deliver the system, component, or service with [organization-defined parameter] implemented; and (b) Use the configurations as the default for any subsequent system, component, or service reinstallation or upgrade. Supplemental Guidance: Require the developer of the system, system component, or system service to: (a)

NIST SP 800-53 Rev 5 control SA-8.18 (Trusted Communications Channels) is assessed by examining, interviewing, and testing: SA-8.18 · Trusted Communications Channels Control Statement: Implement the security design principle of trusted communications channels in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of trusted communications channels in [organization-defined parameter]. The principle of trusted communication channels states that when composing a system where there is a potential threat to communications between components (i.e., the interconnections between

Under the FedRAMP High baseline, SA-4.1 (SA-4.1 Functional Properties of Controls): FedRAMP High

Baseline · SA-4.1 · Functional Properties of Controls Control Statement: Require the developer of the system, system component, or system service to provide a description of the functional properties of the controls to be implemented. Supplemental Guidance: Require the developer of the system, system component, or system service to provide a description of the functional properties of the controls to be implemented. Functional properties of security and privacy controls describe t

Under the FedRAMP High baseline, SA-8 (SA-8 Security and Privacy Engineering Principles): FedRAMP High Baseline · SA-8 · Security and Privacy Engineering Principles Control Statement: Apply the following systems security and privacy engineering principles in the specification, design, development, implementation, and modification of the system and system components: [organization-defined parameter]. Supplemental Guidance: Apply the following systems security and privacy engineering principles in the specification, design, development, implementation, and modification of the system

NIST SP 800-53 Rev 5 control SA-2 (Allocation of Resources) summarizes the requirements for this control: SA-2 · Allocation of Resources Control Statement: a. Determine the high-level information security and privacy requirements for the system or system service in mission and business process planning; b. Determine, document, and allocate the resources required to protect the system or system service as part of the organizational capital planning and investment control process; and c. Establish a discrete line item for information security and privacy in organizational programming and budgeting do

NIST SP 800-53 Rev 5 control SA-4.7 (NIAP-approved Protection Profiles) is assessed by examining, interviewing, and testing: SA-4.7 · NIAP-approved Protection Profiles Control Statement: (a) Limit the use of commercially provided information assurance and information assurance-enabled information technology products to those products that have been successfully evaluated against a National Information Assurance partnership (NIAP)-approved Protection Profile for a specific technology type, if such a profile exists; and (b) Require, if no NIAP-approved Protection Profile exists for a specific technology type but a com

NIST SP 800-171 Rev 3 control 03.16.03 (03.16.03 External System Services) is assessed by examining the following: Assessment Objectives: - the providers of external system services used for the processing, storage, or transmission of CUI comply with the following security requirements: [organization-defined parameter]. - processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis are implemented. - user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers, are defined and documented.

NIST SP 800-53 Rev 5 control SA-22 (Unsupported System Components) summarizes the requirements for this control: SA-22 · Unsupported System Components Control Statement: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the following options for alternative sources for continued support for unsupported components [organization-defined parameter]. Supplemental Guidance: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the

NIST SP 800-53 Rev 5 control SA-8.16 (Self-reliant Trustworthiness) is assessed by examining, interviewing, and testing: SA-8.16 · Self-reliant Trustworthiness Control Statement: Implement the security design principle of self-reliant trustworthiness in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of self-reliant trustworthiness in [organization-defined parameter]. The principle of self-reliant trustworthiness states that systems minimize their reliance on other systems for their own trustworthiness. A system is trustworthy by default, and any connection to an

NIST SP 800-53 Rev 5 control SA-3.2 (Use of Live or Operational Data): SA-3.2 · Use of Live or Operational Data Control Statement: (a) Approve, document, and control the use of live data in preproduction environments for the system, system component, or system service; and (b) Protect preproduction environments for the system, system component, or system service at the same impact or classification level as any live data in use within the preproduction environments.

NIST SP 800-53 Rev 5 control SA-8.6 (Minimized Sharing) is defined as follows: SA-8.6 · Minimized Sharing Control Statement: Implement the security design principle of minimized sharing in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of minimized sharing in [organization-defined parameter]. The principle of minimized sharing states that no computer resource is shared between system components (e.g., subjects, processes, functions) unless it is absolutely necessary to do so. Minimized sharing helps to simplify system design and implementation. In order to protect user-domain resources from arbitrary active entities, no

NIST SP 800-53 Rev 5 control SA-11.8 (Dynamic Code Analysis) is defined as follows: SA-11.8 · Dynamic Code Analysis Control Statement: Require the developer of the system, system component, or system service to employ dynamic code analysis tools to identify common flaws and document the results of the analysis. Supplemental Guidance: Require the developer of the system, system component, or system service to employ dynamic code analysis tools to identify common flaws and document the results of the analysis. Dynamic code analysis provides runtime verification of software programs using tools capable of monitoring programs for memory corruption, user privilege issues, and ot

NIST SP 800-53 Rev 5 control SA-8.12 (Hierarchical Protection) summarizes the requirements for this control: SA-8.12 · Hierarchical Protection Control Statement: Implement the security design principle of hierarchical protection in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of hierarchical protection in [organization-defined parameter]. The principle of hierarchical protection states that a component need not be protected from more trustworthy components. In the degenerate case of the most trusted component, it protects itself from all other compo

NIST SP 800-53 Rev 5 control SA-17.4 (Informal Correspondence) summarizes the requirements for this control: SA-17.4 · Informal Correspondence Control Statement: Require the developer of the system, system component, or system service to: (a) Produce, as an integral part of the development process, an informal descriptive top-level specification that specifies the interfaces to security-relevant hardware, software, and firmware in terms of exceptions, error messages, and effects; (b) Show via [organization-defined parameter] that the descriptive top-level specification is consistent with the formal po

Control SA-14: ppliers' capability to meet the disposal requirements. - b) Periodically review the acquirer's organizational disposal process. - c) Ensure the adequacy of the destruction method for controlled items. ## 4.10.7 Integrators - Verification and Validation Requirements - a) Ensure the adequacy of the destruction method for controlled items (e.g., NIST 800-80 controls for removable media). - b) Verify suppliers' security procedures to govern the transfer of elements and acquirer's sensitive information. - c) Ensure that items subject to controlled disposal are accurately identified, marked, and recorded for traceability. ## 4.10.8 Suppliers - Verification and Validation Requirements - a) Regularly review the disposal process. - b) Verify and validate the identification and tracking of items subject to preservation for forensics and evidentiary purposes and/or controlled disposal.

Control SA-8: f trustworthiness established in a bottom-up fashion. In this approach, the lower-level components check for data integrity and correct functionality (to a limited extent) of higher-level components. For example, trusted boot sequences involve a trusted lower-level component that attests to the trustworthiness of the next higher-level components so that a transitive chain of trust can be established. At the root, a component attests to itself, which usually involves an axiomatic or environmentally enforced assumption about its integrity. Results of the self-analyses can be used to guard against externally induced errors, internal malfunction, or transient errors. By following this principle, some simple malfunctions or errors can be detected without allowing the effects of the error or malfunction to propagate outside of the component. Further, the self-test can be used to attest to the configuration of the component, detecting any potential conflicts in configuration with respect to the expected configuration. Related Controls: CA-7. (22) SECURITY AND PRIVACY ENGINEERING PRINCIPLES | ACCOUNTABILITY AND TRACEABILITY CHAPTER THREE PAGE 265 T h s i p u b l i c a t i o n i s a v a i l a b e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5> I. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Implement the security design principle of accountability and traceability in [Assignment: organization-defined systems or system components]. Discussion: The principle of accountability and traceability states that it is possible to trace security-relevant actions (i.e., subject-object interactions) to the entity on whose behalf the action is being taken.

NIST SP 800-53 Rev 5 control SA-17.2 (Security-relevant Components) summarizes the requirements for this control: SA-17.2 · Security-relevant Components Control Statement: Require the developer of the system, system component, or system service to: (a) Define security-relevant hardware, software, and firmware; and (b) Provide a rationale that the definition for security-relevant hardware, software, and firmware is complete. Supplemental Guidance: Require the developer of the system, system component, or system service to: (a) Define security-relevant hardware, software, and firmware; and (b) Provide a rationale that the definition for security-relevant hardware, software, and firmware is complete.

NIST SP 800-171 Rev 3 control 03.16.02 (03.16.02 Unsupported System Components) is assessed by examining the following: Assessment Objectives: - options for risk mitigation or alternative sources for continued support for unsupported components that cannot be replaced are provided. - system components are replaced when support for the components is no longer available from the developer, vendor, or manufacturer.

NIST SP 800-171 Rev 3 control 03.16.01 (03.16.01 Security Engineering Principles) is assessed by examining the following: Assessment Objectives: - [organization-defined parameter] are applied to the development or modification of the system and system components.

Control SA-4: e required functionality is implemented and possesses the required strength of mechanism. [SP 800-160-1] describes the process of requirements engineering as part of the system development life cycle. Controls can be viewed as descriptions of the safeguards and protection capabilities appropriate for achieving the particular security and privacy objectives of the organization and for reflecting the security and privacy requirements of stakeholders. Controls are selected and implemented in order to satisfy system requirements and include developer and organizational responsibilities. Controls can include technical, administrative, and physical aspects. In some cases, the selection and implementation of a control may necessitate additional specification by the organization in the form of derived requirements or instantiated control parameter values. The derived requirements and control parameter values may be necessary to provide the appropriate level of implementation detail for controls within the system development life cycle. Security and privacy documentation requirements address all stages of the system development life cycle. Documentation provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation is based on the security categorization or classification level of the system and the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement. Related Controls: CM-6, CM-8, PS-7, SA-3, SA-5, SA-8, SA-11, SA-15, SA-16, SA-17, SA-21, SR-3,

NIST SP 800-53 Rev 5 control SA-8.24 (Secure Failure and Recovery) is assessed by examining, interviewing, and testing: SA-8.24 · Secure Failure and Recovery Control Statement: Implement the security design principle of secure failure and recovery in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of secure failure and recovery in [organization-defined parameter]. The principle of secure failure and recovery states that neither a failure in a system function or mechanism nor any recovery action in response to failure leads to a violation of security policy. The p

Under the FedRAMP Low baseline, SA-9 (SA-9 External System Services): FedRAMP Low Baseline · SA-9 · External System Services Control Statement: a. Require that providers of external system services comply with organizational security and privacy requirements and employ the following controls: [organization-defined parameter]; b. Define and document organizational oversight and user roles and responsibilities with regard to external system services; and c. Employ the following processes, methods, and techniques to monitor control compliance by external service pro

Under the FedRAMP Moderate baseline, SA-22 (SA-22 Unsupported System Components): FedRAMP Moderate

Baseline · SA-22 · Unsupported System Components Control Statement: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the following options for alternative sources for continued support for unsupported components [organization-defined parameter]. Supplemental Guidance: a. Replace system components when support for the components is no longer available from the developer, vendor, or man

NIST SP 800-53 Rev 5 control SA-17 (Developer Security and Privacy Architecture and Design) summarizes the requirements for this control: SA-17 · Developer Security and Privacy Architecture and Design Control Statement: Require the developer of the system, system component, or system service to produce a design specification and security and privacy architecture that: a. Is consistent with the organization-s security and privacy architecture that is an integral part the organization-s enterprise architecture; b. Accurately and completely describes the required security and privacy functionality, and the allocation of controls amo

NIST SP 800-53 Rev 5 control SA-1 (Policy and Procedures) summarizes the requirements for this control: SA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] system and services acquisition policy that: 2. Procedures to facilitate the implementation of the system and services acquisition policy and the associated system and services acquisition controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the system and services a

NIST SP 800-53 Rev 5 control SA-11.2 (Threat Modeling and Vulnerability Analyses) summarizes the requirements for this control: SA-11.2 · Threat Modeling and Vulnerability Analyses Control Statement: Require the developer of the system, system component, or system service to perform threat modeling and vulnerability analyses during development and the subsequent testing and evaluation of the system, component, or service that: (a) Uses the following contextual information: [organization-defined parameter]; (b) Employs the following tools and methods: [organization-defined parameter]; (c) Conducts the modeling and analysis

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.14.07E Withdrawn Addressed by 03.14.08E, 03.14.10E, 03.14.14E, 03.17.03E, 03.16.01 (SP 800-171) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.14.08E Integrity Checks 2156

NIST SP 800-53 Rev 5 control SA-4.6 (Use of Information Assurance Products) is assessed by examining, interviewing, and testing: SA-4.6 · Use of Information Assurance Products Control Statement: (a) Employ only government off-the-shelf or commercial off-the-shelf information assurance and information assurance-enabled information technology products that compose an NSA-approved solution to protect classified information when the networks used to transmit the information are at a lower classification level than the information being transmitted; and (b) Ensure that these products have been evaluated and/or validated by NS

Control PD-200901022: tiess of [Assignment: organization- defined security critical or essential software, firmware, and hardware components] using [Assignment: organization-defined verification methods or techniques]. | x | | SA-17 | Developer Security and Privacy Architecture and Design |

_____ ##

APPENDIX D ## ADVERSARY EFFECTS POTENTIAL EFFECTS ON THREAT EVENTS AND RISK yber resiliency solutions are relevant only if they have some effect on risk, specifically by reducing the likelihood of the occurrence of threat events, 32 the ability of threat events to cause harm, and the extent of that harm. 33 The types of analysis of system architectures, designs, implementations, and operations that are indicated for cyber resiliency can include consideration of what effects alternatives could have on the threat events which are part of threat scenarios of concern to organizations. C From the perspective of protecting a system against adversarial threats, five high-level, desired effects on the adversary can be identified: redirect , preclude , impede , limit , and expose . These effects are useful for discussion but are often too general to facilitate the definition of specific measures of effectiveness.

NIST SP 800-53 Rev 5 control SA-4.10 (Use of Approved PIV Products): SA-4.10 · Use of Approved PIV Products Control Statement: Employ only information technology products on the FIPS 201-approved

products list for Personal Identity Verification (PIV) capability implemented within organizational systems. Supplemental Guidance: Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability impl

NIST SP 800-53 Rev 5 control SA-9.1 (Risk Assessments and Organizational Approvals) summarizes the requirements for this control: SA-9.1 · Risk Assessments and Organizational Approvals Control Statement: (a) Conduct an organizational assessment of risk prior to the acquisition or outsourcing of information security services; and (b) Verify that the acquisition or outsourcing of dedicated information security services is approved by [organization-defined parameter]. Supplemental Guidance: (a) Conduct an organizational assessment of risk prior to the acquisition or outsourcing of information security services; and (b) Veri

NIST SP 800-53 Rev 5 control SA-22 (Unsupported System Components) is assessed by examining, interviewing, and testing: SA-22 · Unsupported System Components Control Statement: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the following options for alternative sources for continued support for unsupported components [organization-defined parameter]. Supplemental Guidance: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the

SA-17.3 · Formal Correspondence Control Statement: Require the developer of the system, system component, or system service to: (a) Produce, as an integral part of the development process, a formal top-level specification that specifies the interfaces to security-relevant hardware, software, and firmware in terms of exceptions, error messages, and effects; (b) Show via proof to the extent feasible with additional informal demonstration as necessary, that the formal top-level specification is consistent with the formal policy model; (c) Show via informal demonstration, that the formal top-level specification completely covers the interfaces to security-relevant hardware, software, and firmware; (d) Show that the formal top-level specification is an accurate description of the implemented security-relevant hardware, software, and firmware; and (e) Describe the security-relevant hardware, software, and firmware mechanisms not addressed in the formal top-level specification but strictly internal to the security-relevant hardware, software, and firmware. Supplemental Guidance: Require the developer of the system, system component, or system service to: (a) Produce, as an integral part of the development process, a formal top-level specification that specifies the interfaces to security-relevant hardware, software, and firmware in terms of exceptions, error messages, and effects; (b) Show via proof to the extent feasible with additional informal demonstration as necessary, that the formal top-level specification is consistent with the formal policy model; (c) Show via informal demonstration, that the formal top-level specification completely covers the interfaces to security-relevant hardware, software, and firmware; (d) Show that the formal top-level specification is an accurate description of the implemented security-relevant hardware, software, and firmware; and (e) Describe the security-relevant hardware, software, and firmware mechanisms not addressed in the formal top-level specification but strictly internal to the security-relevant hardware, software, and firmware. Correspondence is an important part of the assurance gained through modeling. It demonstrates that the implementation is an accurate transformation of the model, and that any additional code or implementation details that are present have no impact on the behaviors or policies being modeled. Formal methods can be used to show that the high-level security properties are satisfied by the formal system description, and that the formal system description is correctly implemented by a description of some lower level, including a hardware description. Consistency between the formal top-level specification and the formal policy models is generally not amenable to being fully proven. Therefore, a combination of formal and informal methods may be needed to demonstrate such consistency. Consistency between the formal top-level specification and the actual implementation may require the use of an informal demonstration due to limitations on the applicability of formal methods to prove that the specification accurately reflects the implementation. Hardware, software, and firmware mechanisms internal to security-relevant components include mapping registers and direct memory input and output.

NIST SP 800-53 Rev 5 control SA-8.10 (Hierarchical Trust) is assessed by examining, interviewing, and testing: SA-8.10 · Hierarchical Trust Control Statement: Implement the security design principle of hierarchical trust in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of hierarchical trust in [organization-defined parameter].

The principle of hierarchical trust for components builds on the principle of trusted components and states that the security dependencies in a system will form a partial ordering if they preserve the principle of trusted compone

Under the FedRAMP High baseline, SA-9.1 (SA-9.1 Risk Assessments and Organizational Approvals): FedRAMP High Baseline · SA-9.1 · Risk Assessments and Organizational Approvals Control Statement: (a) Conduct an organizational assessment of risk prior to the acquisition or outsourcing of information security services; and (b) Verify that the acquisition or outsourcing of dedicated information security services is approved by [organization-defined parameter]. Supplemental Guidance: (a) Conduct an organizational assessment of risk prior to the acquisition or outsourcing of information securit

NIST SP 800-53 Rev 5 control SA-15.12 (Minimize Personally Identifiable Information) is assessed by examining, interviewing, and testing: SA-15.12 · Minimize Personally Identifiable Information Control Statement: Require the developer of the system or system component to minimize the use of personally identifiable information in development and test environments. Supplemental Guidance: Require the developer of the system or system component to minimize the use of personally identifiable information in development and test environments. Organizations can minimize the risk to an individual-s privacy by using techniques such as de-

NIST SP 800-53 Rev 5 control SA-8.8 (Secure Evolvability) is assessed by examining, interviewing, and testing: SA-8.8 · Secure Evolvability Control Statement: Implement the security design principle of secure evolvability in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of secure evolvability in [organization-defined parameter]. The principle of secure evolvability states that a system is developed to facilitate the maintenance of its security properties when there are changes to the system-s structure, interfaces, interconnections (i.e., system archit

Under the FedRAMP High baseline, SA-4.10 (SA-4.10 Use of Approved PIV Products): FedRAMP High Baseline · SA-4.10 · Use of Approved PIV Products Control Statement: Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational systems. Supplemental Guidance: Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational systems. Products on the FIPS 201-approved pro

reconfiguration] on [Assignment: organization-defined systems or system components] supporting mission essential services or functions to increase the trustworthiness in those systems or components. Discussion: It is often necessary for a system or system component that supports mission- essential services or functions to be enhanced to maximize the trustworthiness of the resource. Sometimes this enhancement is done at the design level. In other instances, it is done post- design, either through modifications of the system in question or by augmenting the system with additional components. For example, supplemental authentication or non-repudiation functions may be added to the system to enhance the identity of critical resources to other resources that depend on the organization-defined resources. Related Controls: RA-9, SA-8. Control Enhancements: None. References: [SP 800-160-1], [SP 800-160-2]. CHAPTER THREE PAGE 291 T h s i p u b l i c a t i o n i s a v a i l a b e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5>. I NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

3.18 SYSTEM AND COMMUNICATIONS PROTECTION Quick link to System and Communications Protection Summary Table

Control SA-8(13): s i p u b l i c a t i o n i s a v a i l a b e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5>. I NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

CONTROL NUMBER	CONTROL NAME	CONTROL ENHANCEMENT NAME	IMPLEMENTED BY ASSURANCE
----------------	--------------	--------------------------	--------------------------

NIST SP 800-53 Rev 5 control SA-11.1 (Static Code Analysis): SA-11.1 · Static Code Analysis

Control Statement: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Supplemental Guidance: Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document

NIST SP 800-53 Rev 5 control SA-23 (Specialization) is assessed by examining, interviewing, and testing: SA-23 · Specialization Control Statement: Employ [organization-defined parameter] on [organization-defined parameter] supporting mission essential services or functions to increase the trustworthiness in those systems or components. Supplemental Guidance: Employ [organization-defined parameter] on [organization-defined parameter] supporting mission essential services or functions to increase the trustworthiness in those systems or components. It is often necessary for a system or system compon

NIST SP 800-53 Rev 5 control SA-11.7 (Verify Scope of Testing and Evaluation) is defined as follows: SA-11.7 · Verify Scope of Testing and Evaluation Control Statement: Require the developer of the system, system component, or system service to verify that the scope of testing and evaluation provides complete coverage of the required controls at the following level of rigor: [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to verify that the scope of testing and evaluation provides complete coverage of the required controls at the following level of rigor: [organization-defined parameter]. Verifying that testin

NIST SP 800-53 Rev 5 control SA-8.1 (Clear Abstractions) summarizes the requirements for this control: SA-8.1 · Clear Abstractions Control Statement: Implement the security design principle of clear abstractions. Supplemental Guidance: Implement the security design principle of clear abstractions. The principle of clear abstractions states that a system has simple, well-defined interfaces and functions that provide a consistent and intuitive view of the data and how the data is managed. The clarity, simplicity, necessity, and sufficiency of the system interfaces· combined with a precise definit

NIST SP 800-53 Rev 5 control SA-15.12 (Minimize Personally Identifiable Information) summarizes the requirements for this control: SA-15.12 · Minimize Personally Identifiable Information Control Statement: Require the developer of the system or system component to minimize the use of personally identifiable information in development and test environments. Supplemental Guidance: Require the developer of the system or system component to minimize the use of personally identifiable information in development and test environments. Organizations can minimize the risk to an individual-s privacy by using techniques such as de-

NIST SP 800-53 Rev 5 control SA-8.9 (Trusted Components) is assessed by examining, interviewing, and testing: SA-8.9 · Trusted Components Control Statement: Implement the security design principle of trusted components in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of trusted components in [organization-defined parameter]. The principle of trusted components states that a component is trustworthy to at least a level commensurate with the security dependencies it supports (i.e., how much it is trusted to perform its security functions by other compon

From the NIST SP 800-172 Rev 3 Final Public Draft: ADVERSARY EFFECTS 2493 Pre clude (Preempt, Negate), Impede (Exert), Limit (Reduce) REFERENCES Source Control: PL-08(02) 3.16. Sy stem and Services Acquisition 03.16.01 E Specialization E mploy [Selection (one or more): design; modification; augmentation; reconfiguration] on [Assignment: organization-defined systems or system components] supporting mission-essential services or functions to increase the trustworthiness in those systems or components. DISCUSSION Systems or system components that support mission-essential services or functions can be enhanced or strengthened to maximize the trustworthiness of the resource. Sometimes, this enhancement or strengthening is done at the design level. In other instances, it is done post-design, either through modifications of the syst

NIST SP 800-53 Rev 5 control SA-10 (Developer Configuration Management) summarizes the requirements for this control: SA-10 · Developer Configuration Management Control Statement: Require the developer of the system, system component, or system service to: a. Perform configuration management during system, component, or service [organization-defined parameter]; b. Document, manage, and

control the integrity of changes to [organization-defined parameter]; c. Implement only organization-approved changes to the system, component, or service; d. Document approved changes to the system, component, or service and th

NIST SP 800-53 Rev 5 control SA-5 (System Documentation) summarizes the requirements for this control: SA-5 · System Documentation Control Statement: a. Obtain or develop administrator documentation for the system, system component, or system service that describes: 1. Secure configuration, installation, and operation of the system, component, or service; 2. Effective use and maintenance of security and privacy functions and mechanisms; and 3. Known vulnerabilities regarding configuration and use of administrative or privileged functions; b. Obtain or develop user documentation for the sys

NIST SP 800-171 Rev 3 control 03.16.01 (03.16.01 Security Engineering Principles) is assessed by examining the following: Assessment Objectives: - [organization-defined parameter] are applied to the development or modification of the system and system components.

NIST SP 800-53 Rev 5 control SA-8.13 (Minimized Security Elements) is assessed by examining, interviewing, and testing: SA-8.13 · Minimized Security Elements Control Statement: Implement the security design principle of minimized security elements in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of minimized security elements in [organization-defined parameter]. The principle of minimized security elements states that the system does not have extraneous trusted components. The principle of minimized security elements has two aspects: the overall cost of securit

NIST SP 800-53 Rev 5 control SA-8.3 (Modularity and Layering) summarizes the requirements for this control: SA-8.3 · Modularity and Layering Control Statement: Implement the security design principles of modularity and layering in [organization-defined parameter]. Supplemental Guidance: Implement the security design principles of modularity and layering in [organization-defined parameter]. The principles of modularity and layering are fundamental across system engineering disciplines. Modularity and layering derived from functional decomposition are effective in managing system complexity by making

SA-10 · Developer Configuration Management Control Statement: Require the developer of the system, system component, or system service to: a. Perform configuration management during system, component, or service [organization-defined parameter]; b. Document, manage, and control the integrity of changes to [organization-defined parameter]; c. Implement only organization-approved changes to the system, component, or service; d. Document approved changes to the system, component, or service and the potential security and privacy impacts of such changes; and e. Track security flaws and flaw resolution within the system, component, or service and report findings to [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to: a. Perform configuration management during system, component, or service [organization-defined parameter]; b. Document, manage, and control the integrity of changes to [organization-defined parameter]; c. Implement only organization-approved changes to the system, component, or service; d. Document approved changes to the system, component, or service and the potential security and privacy impacts of such changes; and e. Track security flaws and flaw resolution within the system, component, or service and report findings to [organization-defined parameter]. Organizations consider the quality and completeness of configuration management activities conducted by developers as direct evidence of applying effective security controls. Controls include protecting the master copies of material used to generate security-relevant portions of the system hardware, software, and firmware from unauthorized modification or destruction. Maintaining the integrity of changes to the system, system component, or system service requires strict configuration control throughout the system development life cycle to track authorized changes and prevent unauthorized changes. The configuration items that are placed under configuration management include the formal model; the functional, high-level, and low-level design specifications; other design data; implementation documentation; source code and hardware schematics; the current running version of the object code; tools for comparing new versions of security-relevant hardware descriptions and source code with previous versions; and test fixtures and documentation. Depending on the mission and business needs of organizations and the nature of the contractual relationships in place, developers may provide configuration management support during the operations and maintenance stage of the system development life cycle.

Control SA-14: CRITICALITY ANALYSIS [Withdrawn: Incorporated into RA-9.] Control Enhancements: (1) CRITICALITY ANALYSIS | CRITICAL COMPONENTS WITH NO VIABLE ALTERNATIVE SOURCING [Withdrawn: Incorporated into SA-20.]

Control SA-11: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5
SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

(1) DEVELOPER TESTING AND EVALUATION | STATIC CODE ANALYSIS Require the developer of the system, system component, or system service to employ static code analysis tools to identify common flaws and document the results of the analysis. Discussion: Static code analysis provides a technology and methodology for security reviews and includes checking for weaknesses in the code as well as for the incorporation of libraries or other included code with known vulnerabilities or that are out-of-date and not supported. Static code analysis can be used to identify vulnerabilities and enforce secure coding practices. It is most effective when used early in the development process, when each code change can automatically be scanned for potential weaknesses. Static code analysis can provide clear remediation guidance and identify defects for developers to fix. Evidence of the correct implementation of static analysis can include aggregate defect density for critical defect types, evidence that defects were inspected by developers or security professionals, and evidence that defects were remediated. A high density of ignored findings, commonly referred to as false positives, indicates a potential problem with the analysis process or the analysis tool. In such cases, organizations weigh the validity of the evidence against evidence from other sources. Related Controls: None.

NIST SP 800-53 Rev 5 control SA-8.26 (Performance Security) is defined as follows: SA-8.26 · Performance Security Control Statement: Implement the security design principle of performance security in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of performance security in [organization-defined parameter]. The principle of performance security states that security mechanisms are constructed so that they do not degrade system performance unnecessarily. Stakeholder and system design requirements for performance and security are precisely articulated and prioritized. For the system implementation to meet its design requirement

NIST SP 800-53 Rev 5 control SA-11.3 (Independent Verification of Assessment Plans and Evidence) is assessed by examining, interviewing, and testing: SA-11.3 · Independent Verification of Assessment Plans and Evidence Control Statement: (a) Require an independent agent satisfying [organization-defined parameter] to verify the correct implementation of the developer security and privacy assessment plans and the evidence produced during testing and evaluation; and (b) Verify that the independent agent is provided with sufficient information to complete the verification process or granted the authority to obtain such information. Supplemental

NIST SP 800-171 Rev 3 control 03.16.02 (03.16.02 Unsupported System Components) is assessed by examining the following: Assessment Objectives: - options for risk mitigation or alternative sources for continued support for unsupported components that cannot be replaced are provided. - system components are replaced when support for the components is no longer available from the developer, vendor, or manufacturer.

NIST SP 800-53 Rev 5 control SA-9.3 (Establish and Maintain Trust Relationship with Providers) summarizes the requirements for this control: SA-9.3 · Establish and Maintain Trust Relationship with Providers Control Statement: Establish, document, and maintain trust relationships with external service providers based on the following requirements, properties, factors, or conditions: [organization-defined parameter]. Supplemental Guidance: Establish, document, and maintain trust relationships with external service providers based on the following requirements, properties, factors, or conditions: [organization-defined parameter]. Trus

SA-11.4 · Manual Code Reviews Control Statement: Require the developer of the system, system component, or system service to perform a manual code review of [organization-defined parameter] using the following processes, procedures, and/or techniques: [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to

perform a manual code review of [organization-defined parameter] using the following processes, procedures, and/or techniques: [organization-defined parameter]. Manual code reviews are usually reserved for the critical software and firmware components of systems. Manual code reviews are effective at identifying weaknesses that require knowledge of the application's requirements or context that, in most cases, is unavailable to automated analytic tools and techniques, such as static and dynamic analysis. The benefits of manual code review include the ability to verify access control matrices against application controls and review detailed aspects of cryptographic implementations and controls.

NIST SP 800-53 Rev 5 control SA-8.2 (Least Common Mechanism) is assessed by examining, interviewing, and testing: SA-8.2 · Least Common Mechanism Control Statement: Implement the security design principle of least common mechanism in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of least common mechanism in [organization-defined parameter]. The principle of least common mechanism states that the amount of mechanism common to more than one user and depended on by all users is minimized [POPEK74](#79453f84-26a4-4995-8257-d32d37ae3) . Mechanism minimizati

NIST SP 800-53 Rev 5 control SA-17.7 (Structure for Least Privilege) summarizes the requirements for this control: SA-17.7 · Structure for Least Privilege Control Statement: Require the developer of the system, system component, or system service to structure security-relevant hardware, software, and firmware to facilitate controlling access with least privilege. Supplemental Guidance: Require the developer of the system, system component, or system service to structure security-relevant hardware, software, and firmware to facilitate controlling access with least privilege. The principle of least privilege

SA-21 · Developer Screening Control Statement: Require that the developer of [organization-defined parameter]: a. Has appropriate access authorizations as determined by assigned [organization-defined parameter] ; and b. Satisfies the following additional personnel screening criteria: [organization-defined parameter]. Supplemental Guidance: Require that the developer of [organization-defined parameter]: a. Has appropriate access authorizations as determined by assigned [organization-defined parameter] ; and b. Satisfies the following additional personnel screening criteria: [organization-defined parameter]. Developer screening is directed at external developers. Internal developer screening is addressed by [PS-3](#ps-3) . Because the system, system component, or system service may be used in critical activities essential to the national or economic security interests of the United States, organizations have a strong interest in ensuring that developers are trustworthy. The degree of trust required of developers may need to be consistent with that of the individuals who access the systems, system components, or system services once deployed. Authorization and personnel screening criteria include clearances, background checks, citizenship, and nationality. Developer trustworthiness may also include a review and analysis of company ownership and relationships that the company has with entities that may potentially affect the quality and reliability of the systems, components, or services being developed. Satisfying the required access authorizations and personnel screening criteria includes providing a list of all individuals who are authorized to perform development activities on the selected system, system component, or system service so that organizations can validate that the developer has satisfied the authorization and screening requirements.

NIST SP 800-53 Rev 5 control SA-9.8 (Processing and Storage Location · U.S. Jurisdiction): SA-9.8 · Processing and Storage Location · U.S. Jurisdiction Control Statement: Restrict the geographic location of information processing and data storage to facilities located within in the legal jurisdictional boundary of the United States. Supplemental Guidance: Restrict the geographic location of information processing and data storage to facilities located within in the legal jurisdictiona

NIST SP 800-53 Rev 5 control SA-15.6 (Continuous Improvement) summarizes the requirements for this control: SA-15.6 · Continuous Improvement Control Statement: Require the developer of the system, system component, or system service to implement an explicit process to continuously improve the development process. Supplemental Guidance: Require the developer of the system, system component, or system service to implement an explicit process to continuously improve the development process. Developers of systems, system components, and system services consider the effectiveness and efficiency of their

Under the FedRAMP Moderate baseline, SA-9.1 (SA-9.1 Risk Assessments and Organizational Approvals):
FedRAMP Moderate Baseline · SA-9.1 · Risk Assessments and Organizational Approvals Control Statement: (a) Conduct an organizational assessment of risk prior to the acquisition or outsourcing of information security services; and (b) Verify that the acquisition or outsourcing of dedicated information security services is approved by [organization-defined parameter]. Supplemental Guidance: (a) Conduct an organizational assessment of risk prior to the acquisition or outsourcing of information sec

NIST SP 800-53 Rev 5 control SA-8.4 (Partially Ordered Dependencies) is assessed by examining, interviewing, and testing: SA-8.4 · Partially Ordered Dependencies Control Statement: Implement the security design principle of partially ordered dependencies in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of partially ordered dependencies in [organization-defined parameter]. The principle of partially ordered dependencies states that the synchronization, calling, and other dependencies in the system are partially ordered. A fundamental concept in system design is la

NIST SP 800-53 Rev 5 control SA-8.13 (Minimized Security Elements) is defined as follows: SA-8.13 · Minimized Security Elements Control Statement: Implement the security design principle of minimized security elements in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of minimized security elements in [organization-defined parameter]. The principle of minimized security elements states that the system does not have extraneous trusted components. The principle of minimized security elements has two aspects: the overall cost of security analysis and the complexity of security analysis. Trusted components are generally costlier to con

NIST SP 800-53 Rev 5 control SA-8.6 (Minimized Sharing) is assessed by examining, interviewing, and testing: SA-8.6 · Minimized Sharing Control Statement: Implement the security design principle of minimized sharing in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of minimized sharing in [organization-defined parameter]. The principle of minimized sharing states that no computer resource is shared between system components (e.g., subjects, processes, functions) unless it is absolutely necessary to do so. Minimized sharing helps to simplify system des

NIST SP 800-53 Rev 5 control SA-8.17 (Secure Distributed Composition) is assessed by examining, interviewing, and testing: SA-8.17 · Secure Distributed Composition Control Statement: Implement the security design principle of secure distributed composition in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of secure distributed composition in [organization-defined parameter]. The principle of secure distributed composition states that the composition of distributed components that enforce the same system security policy result in a system that enforces that policy a

SA-15.11 · Archive System or Component Control Statement: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review. Supplemental Guidance: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review. Archiving system or system components requires the developer to retain key development artifacts, including hardware specifications, source code, object code, and relevant documentation from the development process that can provide a readily available configuration baseline for system and component upgrades or modifications.

NIST SP 800-53 Rev 5 control SA-9.2 (Identification of Functions, Ports, Protocols, and Services) is assessed by examining, interviewing, and testing: SA-9.2 · Identification of Functions, Ports, Protocols, and Services Control Statement: Require providers of the following external system services to identify the functions, ports, protocols, and other services required for the use of such services: [organization-defined parameter]. Supplemental Guidance: Require providers of the following external system services to identify the functions, ports, protocols, and other services required for the use of such services: [organization-defined param

NIST SP 800-53 Rev 5 control SA-8.23 (Secure Defaults) summarizes the requirements for this control: SA-8.23 · Secure Defaults Control Statement: Implement the security design principle of secure defaults in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of secure defaults in [organization-defined parameter]. The principle of secure defaults states that the default configuration of a system (including its constituent subsystems, components, and mechanisms) reflects a restrictive and conservative enforcement of security policy. The principle of

Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement. System and Services Acquisition 3.16.3 External System Services a. Require the providers of external system services used for the processing, storage, or transmission of CUI to comply with the following security requirements: [Assignment: organization-defined security requirements] (03.16.03.a). b. Define and document user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers. c. Implement processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis. Related Controls: SA-09 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.16.03.a [Assignment: organization-defined security requirements] 1. For cloud service providers: (i) FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline in accordance with the FedRAMP Marketplace; or (ii) meets security requirements established by the government equivalent to the FedRAMP Moderate (or higher) baseline. 2. All other external service providers² must meet NIST SP 800-171 R2. 2 External Service Providers (ESP): External people, technology, or facilities that an organization utilizes for provision and management of IT and/or cybersecurity services on behalf of the organization .

NIST SP 800-53 Rev 5 control SA-8.6 (Minimized Sharing) summarizes the requirements for this control: SA-8.6 · Minimized Sharing Control Statement: Implement the security design principle of minimized sharing in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of minimized sharing in [organization-defined parameter]. The principle of minimized sharing states that no computer resource is shared between system components (e.g., subjects, processes, functions) unless it is absolutely necessary to do so. Minimized sharing helps to simplify system des

NIST SP 800-53 Rev 5 control SA-8.14 (Least Privilege) is assessed by examining, interviewing, and testing: SA-8.14 · Least Privilege Control Statement: Implement the security design principle of least privilege in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of least privilege in [organization-defined parameter]. The principle of least privilege states that each system component is allocated sufficient privileges to accomplish its specified functions but no more. Applying the principle of least privilege limits the scope of the component-s actions

SA-8.13 · Minimized Security Elements Control Statement: Implement the security design principle of minimized security elements in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of minimized security elements in [organization-defined parameter]. The principle of minimized security elements states that the system does not have extraneous trusted components. The principle of minimized security elements has two aspects: the overall cost of security analysis and the complexity of security analysis. Trusted components are generally costlier to construct and implement, owing to the increased rigor of development processes. Trusted components require greater security analysis to qualify their trustworthiness. Thus, to reduce the cost and decrease the complexity of the security analysis, a system contains as few trustworthy components as possible. The analysis of the interaction of trusted components with other components of the system is one of the most important aspects of system security verification. If the interactions between components are unnecessarily complex, the security of the system will also be more difficult to ascertain than one whose internal trust relationships are simple and elegantly constructed. In general, fewer trusted components result in fewer internal trust relationships and a simpler system.

NIST SP 800-53 Rev 5 control SA-4.3 (Development Methods, Techniques, and Practices) summarizes the requirements for this control: SA-4.3 · Development Methods, Techniques, and Practices Control Statement: Require the developer of the system, system component, or system service to demonstrate

the use of a system development life cycle process that includes: (a) [organization-defined parameter]; (b) [organization-defined parameter] ; and (c) [organization-defined parameter].
Supplemental Guidance: Require the developer of the system, system component, or system service to demonstrate the use of a system development life cycle

NIST SP 800-53 Rev 5 control SA-9.5 (Processing, Storage, and Service Location) summarizes the requirements for this control: SA-9.5 · Processing, Storage, and Service Location Control Statement: Restrict the location of [organization-defined parameter] to [organization-defined parameter] based on [organization-defined parameter]. Supplemental Guidance: Restrict the location of [organization-defined parameter] to [organization-defined parameter] based on [organization-defined parameter]. The location of information processing, information and data storage, or system services can have a direct impact on the ability of

NIST SP 800-53 Rev 5 control SA-11.5 (Penetration Testing) is assessed by examining, interviewing, and testing: SA-11.5 · Penetration Testing Control Statement: Require the developer of the system, system component, or system service to perform penetration testing: (a) At the following level of rigor: [organization-defined parameter] ; and (b) Under the following constraints: [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to perform penetration testing: (a) At the following level of rigor: [organization-defined parameter]

NIST SP 800-53 Rev 5 control SA-8.2 (Least Common Mechanism) is defined as follows: SA-8.2 · Least Common Mechanism Control Statement: Implement the security design principle of least common mechanism in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of least common mechanism in [organization-defined parameter]. The principle of least common mechanism states that the amount of mechanism common to more than one user and depended on by all users is minimized [POPEK74](#79453f84-26a4-4995-8257-d32d37ae3333) . Mechanism minimization implies that different components of a system refrain from using the same mechanism to access a s

NIST SP 800-53 Rev 5 control SA-8.11 (Inverse Modification Threshold) is assessed by examining, interviewing, and testing: SA-8.11 · Inverse Modification Threshold Control Statement: Implement the security design principle of inverse modification threshold in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of inverse modification threshold in [organization-defined parameter]. The principle of inverse modification threshold builds on the principle of trusted components and the principle of hierarchical trust and states that the degree of protection provided to a comp

SA-9.7 · Organization-controlled Integrity Checking Control Statement: Provide the capability to check the integrity of information while it resides in the external system. Supplemental Guidance: Provide the capability to check the integrity of information while it resides in the external system. Storage of organizational information in an external system could limit visibility into the security status of its data. The ability of the organization to verify and validate the integrity of its stored data without transferring it out of the external system provides such visibility.

NIST SP 800-53 Rev 5 control SA-15.11 (Archive System or Component) is assessed by examining, interviewing, and testing: SA-15.11 · Archive System or Component Control Statement: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review. Supplemental Guidance: Require the developer of the system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security and privacy review

Under the FedRAMP Moderate baseline, SA-1 (SA-1 Policy and Procedures): FedRAMP Moderate Baseline · SA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] system and services acquisition policy that: 2. Procedures to facilitate the implementation of the system and services acquisition policy and the associated system and services acquisition controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Acceptance criteria for systems,

system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement. System and Services Acquisition 3.16.3 External System Services a. Require the providers of external system services used for the processing, storage, or transmission of CUI to comply with the following security requirements: [Assignment: organization-defined security requirements] (03.16.03.a). b. Define and document user roles and responsibilities with regard to external system services, including shared responsibilities with external service providers. c. Implement processes, methods, and techniques to monitor security requirement compliance by external service providers on an ongoing basis. Related Control

NIST SP 800-53 Rev 5 control SA-10.5 (Mapping Integrity for Version Control) is assessed by examining, interviewing, and testing: SA-10.5 · Mapping Integrity for Version Control Control Statement: Require the developer of the system, system component, or system service to maintain the integrity of the mapping between the master build data describing the current version of security-relevant hardware, software, and firmware and the on-site master copy of the data for the current version. Supplemental Guidance: Require the developer of the system, system component, or system service to maintain the integrity of the mapping

SA-8.1 · Clear Abstractions Control Statement: Implement the security design principle of clear abstractions. Supplemental Guidance: Implement the security design principle of clear abstractions. The principle of clear abstractions states that a system has simple, well-defined interfaces and functions that provide a consistent and intuitive view of the data and how the data is managed. The clarity, simplicity, necessity, and sufficiency of the system interfaces combined with a precise definition of their functional behavior promotes ease of analysis, inspection, and testing as well as the correct and secure use of the system. The clarity of an abstraction is subjective. Examples that reflect the application of this principle include avoidance of redundant, unused interfaces; information hiding; and avoidance of semantic overloading of interfaces or their parameters. Information hiding (i.e., representation-independent programming), is a design discipline used to ensure that the internal representation of information in one system component is not visible to another system component invoking or calling the first component, such that the published abstraction is not influenced by how the data may be managed internally.

Under the FedRAMP High baseline, SA-4 (SA-4 Acquisition Process): FedRAMP High Baseline · SA-4 · Acquisition Process Control Statement: Include the following requirements, descriptions, and criteria, explicitly or by reference, using [organization-defined parameter] in the acquisition contract for the system, system component, or system service: a. Security and privacy functional requirements; b. Strength of mechanism requirements; c. Security and privacy assurance requirements; d. Controls needed to satisfy the security and privacy requirements. e. Security

SA-11.5 · Penetration Testing Control Statement: Require the developer of the system, system component, or system service to perform penetration testing: (a) At the following level of rigor: [organization-defined parameter] ; and (b) Under the following constraints: [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to perform penetration testing: (a) At the following level of rigor: [organization-defined parameter] ; and (b) Under the following constraints: [organization-defined parameter]. Penetration testing is an assessment methodology in which assessors, using all available information technology product or system documentation and working under specific constraints, attempt to circumvent the implemented security and privacy features of information technology products and systems. Useful information for assessors who conduct penetration testing includes product and system design specifications, source code, and administrator and operator manuals. Penetration testing can include white-box, gray-box, or black-box testing with analyses performed by skilled professionals who simulate adversary actions. The objective of penetration testing is to discover vulnerabilities in systems, system components, and services that result from implementation errors, configuration faults, or other operational weaknesses or deficiencies. Penetration tests can be performed in conjunction with automated and manual code reviews to provide a greater level of analysis than would ordinarily be possible. When user session information and other personally identifiable information is captured or recorded during penetration testing, such information is handled appropriately to protect privacy.

NIST SP 800-53 Rev 5 control SA-17.3 (Formal Correspondence) is assessed by examining, interviewing, and testing: SA-17.3 · Formal Correspondence Control Statement: Require the developer of the

system, system component, or system service to: (a) Produce, as an integral part of the development process, a formal top-level specification that specifies the interfaces to security-relevant hardware, software, and firmware in terms of exceptions, error messages, and effects; (b) Show via proof to the extent feasible with additional informal demonstration as necessary, that the formal top-level specification is co

Under the FedRAMP Moderate baseline, SA-3 (SA-3 System Development Life Cycle): FedRAMP Moderate Baseline · SA-3 · System Development Life Cycle Control Statement: a. Acquire, develop, and manage the system using [organization-defined parameter] that incorporates information security and privacy considerations; b. Define and document information security and privacy roles and responsibilities throughout the system development life cycle; c. Identify individuals having information security and privacy roles and responsibilities; and d. Integrate the organizational informati

NIST SP 800-53 Rev 5 control SA-15.2 (Security and Privacy Tracking Tools) is defined as follows: SA-15.2 · Security and Privacy Tracking Tools Control Statement: Require the developer of the system, system component, or system service to select and employ security and privacy tracking tools for use during the development process. Supplemental Guidance: Require the developer of the system, system component, or system service to select and employ security and privacy tracking tools for use during the development process. System development teams select and deploy security and privacy tracking tools, including vulnerability or work item tracking systems that facilitate assignment, sorting,

SA-15.2 · Security and Privacy Tracking Tools Control Statement: Require the developer of the system, system component, or system service to select and employ security and privacy tracking tools for use during the development process. Supplemental Guidance: Require the developer of the system, system component, or system service to select and employ security and privacy tracking tools for use during the development process. System development teams select and deploy security and privacy tracking tools, including vulnerability or work item tracking systems that facilitate assignment, sorting, filtering, and tracking of completed work items or tasks associated with development processes.

NIST SP 800-53 Rev 5 control SA-8.22 (Accountability and Traceability) is defined as follows: SA-8.22 · Accountability and Traceability Control Statement: Implement the security design principle of accountability and traceability in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of accountability and traceability in [organization-defined parameter]. The principle of accountability and traceability states that it is possible to trace security-relevant actions (i.e., subject-object interactions) to the entity on whose behalf the action is being taken. The principle of accountability and traceability requires a trustworthy infrastructure

NIST SP 800-171 Rev 3 control 03.16.02 (03.16.02 Unsupported System Components) requires organizations to implement the following: Control Statement: SR-03.16.02.a Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer. SR-03.16.02.b Provide options for risk mitigation or alternative sources for continued support for unsupported components that cannot be replaced. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.16.02.

NIST SP 800-53 Rev 5 control SA-8.18 (Trusted Communications Channels) summarizes the requirements for this control: SA-8.18 · Trusted Communications Channels Control Statement: Implement the security design principle of trusted communications channels in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of trusted communications channels in [organization-defined parameter]. The principle of trusted communication channels states that when composing a system where there is a potential threat to communications between components (i.e., the interconnections between

NIST SP 800-53 Rev 5 control SA-15.6 (Continuous Improvement): SA-15.6 · Continuous Improvement Control Statement: Require the developer of the system, system component, or system service to implement an explicit process to continuously improve the development process. Supplemental Guidance: Require the developer of the system, system component, or system service to implement an

explicit process to continuously improve the development process. Developers of

NIST SP 800-53 Rev 5 control SA-9.6 (Organization-controlled Cryptographic Keys) is assessed by examining, interviewing, and testing: SA-9.6 · Organization-controlled Cryptographic Keys Control Statement: Maintain exclusive control of cryptographic keys for encrypted material stored or transmitted through an external system. Supplemental Guidance: Maintain exclusive control of cryptographic keys for encrypted material stored or transmitted through an external system. Maintaining exclusive control of cryptographic keys in an external system prevents decryption of organizational data by external system staff. Organizational co

NIST SP 800-53 Rev 5 control SA-10.3 (Hardware Integrity Verification) is defined as follows: SA-10.3 · Hardware Integrity Verification Control Statement: Require the developer of the system, system component, or system service to enable integrity verification of hardware components. Supplemental Guidance: Require the developer of the system, system component, or system service to enable integrity verification of hardware components. Hardware integrity verification allows organizations to detect unauthorized changes to hardware components using developer-provided tools, techniques, methods, and mechanisms. Organizations may verify the integrity of hardware components with hard-to-cop

NIST SP 800-53 Rev 5 control SA-17.1 (Formal Policy Model) summarizes the requirements for this control: SA-17.1 · Formal Policy Model Control Statement: Require the developer of the system, system component, or system service to: (a) Produce, as an integral part of the development process, a formal policy model describing the [organization-defined parameter] to be enforced; and (b) Prove that the formal policy model is internally consistent and sufficient to enforce the defined elements of the organizational security and privacy policy when implemented. Supplemental Guidance: Require the develop

SA-17.9 · Design Diversity Control Statement: Use different designs for [organization-defined parameter] to satisfy a common set of requirements or to provide equivalent functionality. Supplemental Guidance: Use different designs for [organization-defined parameter] to satisfy a common set of requirements or to provide equivalent functionality. Design diversity is achieved by supplying the same requirements specification to multiple developers, each of whom is responsible for developing a variant of the system or system component that meets the requirements. Variants can be in software design, in hardware design, or in both hardware and a software design. Differences in the designs of the variants can result from developer experience (e.g., prior use of a design pattern), design style (e.g., when decomposing a required function into smaller tasks, determining what constitutes a separate task and how far to decompose tasks into sub-tasks), selection of libraries to incorporate into the variant, and the development environment (e.g., different design tools make some design patterns easier to visualize). Hardware design diversity includes making different decisions about what information to keep in analog form and what information to convert to digital form, transmitting the same information at different times, and introducing delays in sampling (temporal diversity). Design diversity is commonly used to support fault tolerance.

NIST SP 800-53 Rev 5 control SA-9.7 (Organization-controlled Integrity Checking) summarizes the requirements for this control: SA-9.7 · Organization-controlled Integrity Checking Control Statement: Provide the capability to check the integrity of information while it resides in the external system. Supplemental Guidance: Provide the capability to check the integrity of information while it resides in the external system. Storage of organizational information in an external system could limit visibility into the security status of its data. The ability of the organization to verify and validate the integrity of its sto

NIST SP 800-53 Rev 5 control SA-17.7 (Structure for Least Privilege) is assessed by examining, interviewing, and testing: SA-17.7 · Structure for Least Privilege Control Statement: Require the developer of the system, system component, or system service to structure security-relevant hardware, software, and firmware to facilitate controlling access with least privilege. Supplemental Guidance: Require the developer of the system, system component, or system service to structure security-relevant hardware, software, and firmware to facilitate controlling access with least privilege. The principle of least privilege

Under the FedRAMP Moderate baseline, SA-9.5 (SA-9.5 Processing, Storage, and Service Location):

FedRAMP Moderate Baseline · SA-9.5 · Processing, Storage, and Service Location Control Statement: Restrict the location of [organization-defined parameter] to [organization-defined parameter] based on [organization-defined parameter]. Supplemental Guidance: Restrict the location of [organization-defined parameter] to [organization-defined parameter] based on [organization-defined parameter]. The location of information processing, information and data storage, or system services can have a dir

NIST SP 800-53 Rev 5 control SA-8.10 (Hierarchical Trust): SA-8.10 · Hierarchical Trust Control Statement: Implement the security design principle of hierarchical trust in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of hierarchical trust in [organization-defined parameter]. The principle of hierarchical trust for components builds on the principle of trusted components and states that the security dep

NIST SP 800-53 Rev 5 control SA-22 (Unsupported System Components): SA-22 · Unsupported System Components Control Statement: a. Replace system components when support for the components is no longer available from the developer, vendor, or manufacturer; or b. Provide the following options for alternative sources for continued support for unsupported components [organization-defined parameter]. Supplemental Guidance: a. Replace system components when support for

NIST SP 800-53 Rev 5 control SA-8.28 (Acceptable Security) summarizes the requirements for this control: SA-8.28 · Acceptable Security Control Statement: Implement the security design principle of acceptable security in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of acceptable security in [organization-defined parameter]. The principle of acceptable security requires that the level of privacy and performance that the system provides is consistent with the users' expectations. The perception of personal privacy may affect user behavior, morale,

SA-9.6 · Organization-controlled Cryptographic Keys Control Statement: Maintain exclusive control of cryptographic keys for encrypted material stored or transmitted through an external system. Supplemental Guidance: Maintain exclusive control of cryptographic keys for encrypted material stored or transmitted through an external system. Maintaining exclusive control of cryptographic keys in an external system prevents decryption of organizational data by external system staff. Organizational control of cryptographic keys can be implemented by encrypting and decrypting data inside the organization as data is sent to and received from the external system or by employing a component that permits encryption and decryption functions to be local to the external system but allows exclusive organizational access to the encryption keys.

NIST SP 800-53 Rev 5 control SA-4.5 (System, Component, and Service Configurations) is assessed by examining, interviewing, and testing: SA-4.5 · System, Component, and Service Configurations Control Statement: Require the developer of the system, system component, or system service to: (a) Deliver the system, component, or service with [organization-defined parameter] implemented; and (b) Use the configurations as the default for any subsequent system, component, or service reinstallation or upgrade. Supplemental Guidance: Require the developer of the system, system component, or system service to: (a) Deliver the system, comp

NIST SP 800-53 Rev 5 control SA-10.7 (Security and Privacy Representatives) summarizes the requirements for this control: SA-10.7 · Security and Privacy Representatives Control Statement: Require [organization-defined parameter] to be included in the [organization-defined parameter]. Supplemental Guidance: Require [organization-defined parameter] to be included in the [organization-defined parameter]. Information security and privacy representatives can include system security officers, senior agency information security officers, senior agency officials for privacy, and system privacy officers. Representation by

NIST SP 800-53 Rev 5 control SA-15.10 (Incident Response Plan) summarizes the requirements for this control: SA-15.10 · Incident Response Plan Control Statement: Require the developer of the system, system component, or system service to provide, implement, and test an incident response plan. Supplemental Guidance: Require the developer of the system, system component, or system service to provide, implement, and test an incident response plan. The incident response plan provided by developers may provide information not readily available to organizations and be incorporated into organizational incid

NIST SP 800-53 Rev 5 control SA-20 (Customized Development of Critical Components): SA-20 · Customized Development of Critical Components Control Statement: Reimplement or custom develop the following critical system components: [organization-defined parameter]. Supplemental Guidance: Reimplement or custom develop the following critical system components: [organization-defined parameter]. Organizations determine that certain system components likely cannot be trusted due to spe

NIST SP 800-53 Rev 5 control SA-8.1 (Clear Abstractions) is assessed by examining, interviewing, and testing: SA-8.1 · Clear Abstractions Control Statement: Implement the security design principle of clear abstractions. Supplemental Guidance: Implement the security design principle of clear abstractions. The principle of clear abstractions states that a system has simple, well-defined interfaces and functions that provide a consistent and intuitive view of the data and how the data is managed. The clarity, simplicity, necessity, and sufficiency of the system interfaces· combined with a precise definit

NIST SP 800-53 Rev 5 control SA-4.10 (Use of Approved PIV Products) is defined as follows: SA-4.10 · Use of Approved PIV Products Control Statement: Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational systems. Supplemental Guidance: Employ only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational systems. Products on the FIPS 201-approved products list meet NIST requirements for Personal Identity Verification (PIV) of Federal Employees and Contractors. PIV cards a

NIST SP 800-53 Rev 5 control SA-9.8 (Processing and Storage Location · U.S. Jurisdiction) is assessed by examining, interviewing, and testing: SA-9.8 · Processing and Storage Location · U.S. Jurisdiction Control Statement: Restrict the geographic location of information processing and data storage to facilities located within in the legal jurisdictional boundary of the United States. Supplemental Guidance: Restrict the geographic location of information processing and data storage to facilities located within in the legal jurisdictional boundary of the United States. The geographic location of information processing and data storage

NIST SP 800-53 Rev 5 control SA-8.21 (Self-analysis) is assessed by examining, interviewing, and testing: SA-8.21 · Self-analysis Control Statement: Implement the security design principle of self-analysis in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of self-analysis in [organization-defined parameter]. The principle of self-analysis states that a system component is able to assess its internal state and functionality to a limited extent at various stages of execution, and that this self-analysis capability is commensurate with the level of tr

NIST SP 800-53 Rev 5 control SA-8.27 (Human Factored Security): SA-8.27 · Human Factored Security Control Statement: Implement the security design principle of human factored security in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of human factored security in [organization-defined parameter]. The principle of human factored security states that the user interface for security functions and supporting serv

NIST SP 800-53 Rev 5 control SA-8.22 (Accountability and Traceability): SA-8.22 · Accountability and Traceability Control Statement: Implement the security design principle of accountability and traceability in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of accountability and traceability in [organization-defined parameter]. The principle of accountability and traceability states that it is possible to trace secur

NIST SP 800-53 Rev 5 control SA-8.24 (Secure Failure and Recovery) summarizes the requirements for this control: SA-8.24 · Secure Failure and Recovery Control Statement: Implement the security design principle of secure failure and recovery in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of secure failure and recovery in [organization-defined parameter]. The principle of secure failure and recovery states that neither a failure in a system function or mechanism nor any recovery action in response to failure leads to a violation of security policy. The p

NIST SP 800-53 Rev 5 control SA-17.1 (Formal Policy Model) is assessed by examining, interviewing, and testing: SA-17.1 · Formal Policy Model Control Statement: Require the developer of the system, system component, or system service to: (a) Produce, as an integral part of the development process, a formal policy model describing the [organization-defined parameter] to be enforced; and (b) Prove that the formal policy model is internally consistent and sufficient to enforce the defined elements of the organizational security and privacy policy when implemented. Supplemental Guidance: Require the develop

NIST SP 800-53 Rev 5 control SA-15 (Development Process, Standards, and Tools) is assessed by examining, interviewing, and testing: SA-15 · Development Process, Standards, and Tools Control Statement: a. Require the developer of the system, system component, or system service to follow a documented development process that: 1. Explicitly addresses security and privacy requirements; 2. Identifies the standards and tools used in the development process; 3. Documents the specific tool options and tool configurations used in the development process; and 4. Documents, manages, and ensures the integrity of changes to the

NIST SP 800-53 Rev 5 control SA-1 (Policy and Procedures) is assessed by examining, interviewing, and testing: SA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] system and services acquisition policy that: 2. Procedures to facilitate the implementation of the system and services acquisition policy and the associated system and services acquisition controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the system and services a

NIST SP 800-53 Rev 5 control SA-17.2 (Security-relevant Components) is assessed by examining, interviewing, and testing: SA-17.2 · Security-relevant Components Control Statement: Require the developer of the system, system component, or system service to: (a) Define security-relevant hardware, software, and firmware; and (b) Provide a rationale that the definition for security-relevant hardware, software, and firmware is complete. Supplemental Guidance: Require the developer of the system, system component, or system service to: (a) Define security-relevant hardware, software, and firmware; and (b) Provide a rat

NIST SP 800-53 Rev 5 control SA-8.19 (Continuous Protection) summarizes the requirements for this control: SA-8.19 · Continuous Protection Control Statement: Implement the security design principle of continuous protection in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of continuous protection in [organization-defined parameter]. The principle of continuous protection states that components and data used to enforce the security policy have uninterrupted protection that is consistent with the security policy and the security architecture assumptio

NIST SP 800-53 Rev 5 control SA-11.6 (Attack Surface Reviews) summarizes the requirements for this control: SA-11.6 · Attack Surface Reviews Control Statement: Require the developer of the system, system component, or system service to perform attack surface reviews. Supplemental Guidance: Require the developer of the system, system component, or system service to perform attack surface reviews. Attack surfaces of systems and system components are exposed areas that make those systems more vulnerable to attacks. Attack surfaces include any accessible areas where weaknesses or deficiencies in the har

NIST SP 800-53 Rev 5 control SA-8.30 (Procedural Rigor) is defined as follows: SA-8.30 · Procedural Rigor Control Statement: Implement the security design principle of procedural rigor in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of procedural rigor in [organization-defined parameter]. The principle of procedural rigor states that the rigor of a system life cycle process is commensurate with its intended trustworthiness. Procedural rigor defines the scope, depth, and detail of the system life cycle procedures. Rigorous system life cycle procedures contribute to the assurance that the system is correct and free of u

NIST SP 800-53 Rev 5 control SA-8.21 (Self-analysis): SA-8.21 · Self-analysis Control Statement: Implement the security design principle of self-analysis in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of self-analysis in [organization-

defined parameter]. The principle of self-analysis states that a system component is able to assess its internal state and functionality to a limited extent at vari

NIST SP 800-53 Rev 5 control SA-16 (Developer-provided Training) is assessed by examining, interviewing, and testing: SA-16 · Developer-provided Training Control Statement: Require the developer of the system, system component, or system service to provide the following training on the correct use and operation of the implemented security and privacy functions, controls, and/or mechanisms: [organization-defined parameter]. Supplemental Guidance: Require the developer of the system, system component, or system service to provide the following training on the correct use and operation of the implemented securit

NIST SP 800-53 Rev 5 control SA-8.10 (Hierarchical Trust) summarizes the requirements for this control: SA-8.10 · Hierarchical Trust Control Statement: Implement the security design principle of hierarchical trust in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of hierarchical trust in [organization-defined parameter]. The principle of hierarchical trust for components builds on the principle of trusted components and states that the security dependencies in a system will form a partial ordering if they preserve the principle of trusted compone

NIST SP 800-53 Rev 5 control SA-8.31 (Secure System Modification) summarizes the requirements for this control: SA-8.31 · Secure System Modification Control Statement: Implement the security design principle of secure system modification in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of secure system modification in [organization-defined parameter]. The principle of secure system modification states that system modification maintains system security with respect to the security requirements and risk tolerance of stakeholders. Upgrades or modifications

NIST SP 800-53 Rev 5 control SA-4.1 (Functional Properties of Controls) summarizes the requirements for this control: SA-4.1 · Functional Properties of Controls Control Statement: Require the developer of the system, system component, or system service to provide a description of the functional properties of the controls to be implemented. Supplemental Guidance: Require the developer of the system, system component, or system service to provide a description of the functional properties of the controls to be implemented. Functional properties of security and privacy controls describe the functionality (i.e.,

NIST SP 800-53 Rev 5 control SA-4 (Acquisition Process) is assessed by examining, interviewing, and testing: SA-4 · Acquisition Process Control Statement: Include the following requirements, descriptions, and criteria, explicitly or by reference, using [organization-defined parameter] in the acquisition contract for the system, system component, or system service: a. Security and privacy functional requirements; b. Strength of mechanism requirements; c. Security and privacy assurance requirements; d. Controls needed to satisfy the security and privacy requirements. e. Security and privacy documentatio

SA-8.30 · Procedural Rigor Control Statement: Implement the security design principle of procedural rigor in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of procedural rigor in [organization-defined parameter]. The principle of procedural rigor states that the rigor of a system life cycle process is commensurate with its intended trustworthiness. Procedural rigor defines the scope, depth, and detail of the system life cycle procedures. Rigorous system life cycle procedures contribute to the assurance that the system is correct and free of unintended functionality in several ways. First, the procedures impose checks and balances on the life cycle process such that the introduction of unspecified functionality is prevented. Second, rigorous procedures applied to systems security engineering activities that produce specifications and other system design documents contribute to the ability to understand the system as it has been built rather than trusting that the component, as implemented, is the authoritative (and potentially misleading) specification. Finally, modifications to an existing system component are easier when there are detailed specifications that describe its current design instead of studying source code or schematics to try to understand how it works. Procedural rigor helps ensure that security functional and assurance requirements have been satisfied, and it contributes to a better-informed basis for the determination of trustworthiness and risk posture. Procedural rigor is commensurate with the degree of assurance desired for the system. If the

required trustworthiness of the system is low, a high level of procedural rigor may add unnecessary cost, whereas when high trustworthiness is critical, the cost of high procedural rigor is merited.

NIST SP 800-53 Rev 5 control SA-8.23 (Secure Defaults) is assessed by examining, interviewing, and testing: SA-8.23 · Secure Defaults Control Statement: Implement the security design principle of secure defaults in [organization-defined parameter]. Supplemental Guidance: Implement the security design principle of secure defaults in [organization-defined parameter]. The principle of secure defaults states that the default configuration of a system (including its constituent subsystems, components, and mechanisms) reflects a restrictive and conservative enforcement of security policy. The principle of

NIST SP 800-53 Rev 5 control SA-15.13 (Logging Syntax) is assessed by examining, interviewing, and testing: SA-15.13 · Logging Syntax Control Statement: Require the developer of the system or system component to minimize the use of personally identifiable information in development and test environments. Supplemental Guidance: Require the developer of the system or system component to minimize the use of personally identifiable information in development and test environments. In support of better incident response and the ability to more quickly reconstruct security-related actions, identifying spe